ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Microsoft Windows 11 (Enterprise/IoT Enterprise) · Component type: **Host Device (HDR) - workstation/EWS/OWS** · Target SL = SL 3

Where to work	**Local Security Policy** (`secpol.msc`) / **Group Policy** (`gpedit.msc`, domain GPO); **PowerShell** (`Get-*`); Settings; Event Viewer; `auditpol`; `secedit`. Baseline against the **DISA Windows 11 STIG** / **CIS Benchmark**.
Interfaces / ports	RDP **3389** (NLA); SMB **445** (signed, no v1); WinRM **5985/5986**; LDAP(S) if domain; NetBIOS 137-139 (disable). Manage via console / RDP / WinRM.
Notes	HDR (host device). Confirm build (`winver`) and domain/Azure-AD join. Many controls apply via GPO/Intune; verify effective settings with `gpresult /h` / `rsop.msc`.
How to read	Default read-only (read the effective policy / `Get-*` state). Native how-to + external-tool validation + pass. Scan/exploit tools = **authorized**; write/exploit = isolated env.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.1	Human user I&A;	Confirm interactive logon requires credentials: Guest disabled (`net user guest`), no autologon (`reg query "HKLM\...\Winlogon" /v AutoAdminLogon`), Ctrl+Alt+Del required, cached-creds limited. Domain/Azure-AD SSO where used. **Test:** no anonymous/blank-password logon; Guest cannot log on. **Ext. tools:** SCC/CIS-CAT (STIG scan); `net user` / `whoami /groups`; Nmap (auth services).	All logon requires authentication; Guest disabled; no autologon/blank passwords.	HDR.
SR/CR 1.2	Software process / device identification	Confirm services/tasks run under named service accounts (Managed Service Accounts / gMSA), not shared logons; machine identity is the AD/Azure-AD computer object. Device auth on the network via 802.1X / IPsec where used. **Ext. tools:** Get-Service / Get-ScheduledTask (run-as review); AD computer object review.	Processes/services run under managed identities; unique machine identity.	
SR/CR 1.3	Account management	Review local accounts/groups (`net localgroup administrators`); use **Windows LAPS** for the local admin password; remove extra admins; disable stale accounts. **Ext. tools:** PowerShell (`Get-LocalUser`); AccessChk; STIG scan.	Named, least-priv accounts; LAPS-managed local admin; no stale/shared accounts.	
SR/CR 1.4	Identifier management	In **Local Users and Groups** (`lusrmgr.msc`) / AD Users & Computers, confirm unique user SIDs/UPNs, no shared accounts, renamed/disabled built-in Administrator & Guest, and lifecycle (disable on exit). **Ext. tools:** Get-LocalUser / AD query; STIG check for renamed built-ins.	Unique identifiers; built-ins renamed/disabled; no shared accounts.	
SR/CR 1.5	Authenticator management	`secpol.msc` › Account Policies › **Password Policy**: min length >=14, complexity ON, history 24, max age; Windows Hello for Business where used. Export/verify with `secedit /export /cfg out.inf`. **Ext. tools:** STIG/CIS scan; `net accounts`	Strong password policy enforced (length/complexity/history/age).	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	Confirm machine/user certificates are issued by the enterprise CA (auto-enrollment), valid and revocable; check the store (`certlm.msc`); RDP/WinRM use trusted certs, not self-signed. **Ext. tools:** certlm.msc / Get-ChildItem Cert:; openssl (RDP/WinRM cert).	CA-issued, valid, revocable certificates; defaults replaced.	
SR/CR 1.9	Strength of public key auth	Confirm strong key/algorithm policy: TLS 1.2/1.3 only (disable SSL/TLS1.0/1.1 via Schannel), strong cipher suites, smartcard/Windows Hello for Business where used. **Ext. tools:** testssl.sh (RDP/WinRM/LDAPS); Schannel registry / IISCrypto review.	Strong crypto for cert-based auth; weak protocols disabled.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.10	Authenticator feedback	Confirm the logon UI obscures passwords and "display last user name" is disabled (Interactive logon GPO); no credential echo. **Ext. tools:** secpol / GPO (Interactive logon: Do not display last user name); visual.	Authenticators obscured; last user name not shown.	
SR/CR 1.11	Unsuccessful login attempts	Account Policies › **Account Lockout Policy**: threshold (<=10, e.g. 3-5), duration, reset counter; verify with `net accounts`. **Ext. tools:** STIG scan; `net accounts` review.	Lockout after few failed attempts for a set duration.	
SR/CR 1.12	System use notification	Local Policies › Security Options: **Interactive logon: Message text/title for users attempting to log on** set to the approved banner. Confirm it displays at logon. **Ext. tools:** STIG scan; visual check at logon.	Approved legal/use banner displayed before logon.	
SR 1.13	Access via untrusted networks	RDP with **NLA** + MFA; restrict via Windows Firewall to mgmt subnets; disable SMBv1/NTLMv1; require VPN. **Test:** RDP from untrusted -> blocked/needs MFA. **Ext. tools:** Nmap (3389/445 reachability by segment); firewall rule review.	Remote access requires NLA+MFA and is restricted to mgmt networks.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.1	Authorization enforcement	Least privilege: **UAC** Admin Approval Mode ON, standard users not admins; **AppLocker / WDAC** allow-list; User Rights Assignment reviewed (`secpol.msc` › Local Policies › User Rights). **Test:** standard user cannot install/run disallowed apps. **Ext. tools:** AccessChk (privileges); `Get-AppLockerPolicy -Effective`; STIG scan.	Least privilege enforced; UAC on; app allow-listing active.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control removable media: **Removable Storage Access** GPO (deny write/execute or block) and/or Defender **Device Control**; BitLocker To Go for allowed media; USB storage disabled where policy requires. **Ext. tools:** GPO / Intune device-control review; Get-WmiObject USB enumeration.	Removable-media use controlled per policy; unauthorized media blocked.	
SR/HDR 2.4	Mobile code	Restrict mobile/untrusted code: **AppLocker or WDAC** allow-list for exe/script/MSI/DLL, PowerShell **Constrained Language Mode**, block Office macros from the internet, SmartScreen on. **Ext. tools:** Get-AppLockerPolicy / WDAC policy review; test an unsigned binary (isolated).	Only allow-listed code runs; untrusted mobile code blocked.	HDR-specific.
SR/CR 2.5	Session lock	Security Options: **Interactive logon: Machine inactivity limit** (e.g. 900s) + screen-saver lock via GPO. Verify effective policy. **Ext. tools:** STIG scan; `gpresult /h`	Session locks after inactivity.	
SR/CR 2.6	Remote session termination	Confirm RDP idle/session limits (GPO: set time limit for active/idle RDP sessions, disconnect when limit reached) and screen-lock on inactivity; sessions terminable via admin. **Ext. tools:** GPO (Remote Desktop Session time limits); qwinsta / logoff test.	Remote sessions time out and are terminable on demand.	
SR/CR 2.7	Concurrent session control	Limit concurrent sessions: restrict RDP to single session per user (GPO: Restrict RD users to a single session) and limit simultaneous connections. **Ext. tools:** GPO / RDS config review; qwinsta (active sessions).	Concurrent privileged/RDP sessions limited.	
SR/CR 2.8	Auditable events	Enable **Advanced Audit Policy** (Logon/Logoff, Account Logon, Object Access, Privilege Use, Policy Change, System) — verify `auditpol /get /category:*`; set Event Log sizes; forward via **WEF** to the SIEM. **Test:** a logon/priv-use event is recorded. **Ext. tools:** auditpol; Event Viewer; SIEM/WEF check.	Security-relevant events audited with user + time; forwarded to SIEM.	
SR/CR 2.9	Audit storage capacity	Confirm Security event log sizing/retention (GPO: max log size, retention) and forwarding via **WEF** to the SIEM so events are retained beyond local capacity. **Ext. tools:** wevtutil gl Security (log size); SIEM retention review.	Log capacity sized; events forwarded/retained; no premature overwrite.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.10	Response to audit processing failures	Confirm behavior on audit failure: "Audit: Shut down system immediately if unable to log security audits" per policy, or SIEM alerts on log-forwarding/agent failure. **Ext. tools:** secpol (CrashOnAuditFail); SIEM agent-health alerting.	Defined response to audit failure; alerting on forwarding loss.	
SR/CR 2.11	Timestamps	Time sync: `w32tm /query /status` + `w32tm /query /configuration` to an authenticated NTP/domain source; logs use synced time. **Ext. tools:** `w32tm /query /status`; Wireshark (NTP).	Accurate synchronized time; consistent log timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable: per-user accounts + auditing of privileged use (auditpol categories: Logon, Privilege Use, Object Access, Policy Change) so actions bind to an identity. **Ext. tools:** auditpol /get /category:*; Event Viewer (4624/4672/4688).	Actions attributable to unique users; privileged use audited.	
HDR 2.13	Physical / diagnostic interfaces	Control removable media / USB (GPO Removable Storage Access; Defender device control); disable boot from USB in UEFI (password-protected UEFI); disable unused ports/console access. **Ext. tools:** STIG scan; UEFI/boot-order review; physical inspection.	USB/boot/diagnostic interfaces controlled; UEFI password set.	HDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 3.1	Communication integrity	Require **SMB signing** (Microsoft network client/server: Digitally sign communications = Enabled), **LDAP signing**, disable **SMBv1** (`Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`) and NTLMv1; RDP NLA. **Ext. tools:** STIG scan; Nmap smb2-security-mode; Wireshark.	SMB/LDAP signing on; SMBv1/NTLMv1 disabled; sessions integrity-protected.	
SR/HDR 3.2	Protection from malicious code	**Microsoft Defender AV** + **ASR rules** + **Tamper Protection** + SmartScreen + Controlled Folder Access; verify `Get-MpComputerStatus` (RealTimeProtectionEnabled, AMServiceEnabled) and `Get-MpPreference` (ASR). WDAC/AppLocker allow-list. **Ext. tools:** `Get-MpComputerStatus`; STIG scan.	AV/ASR/tamper-protection on and current; execution allow-listed.	HDR-specific.
SR/CR 3.3	Security functionality verification	Re-verify hardening after change: run a **SCAP/STIG** scan (SCC / STIG Viewer) or CIS-CAT against the baseline; confirm no drift in policy, services, or Defender state. **Ext. tools:** DISA SCC / OpenSCAP (oscap) vs Win11 STIG; CIS-CAT.	Configuration matches the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	**UEFI Secure Boot** (`Confirm-SecureBootUEFI`), **HVCI / Memory Integrity** and WDAC code integrity, signed drivers; **TPM 2.0** present (`Get-Tpm`). **Ext. tools:** `Confirm-SecureBootUEFI`; `Get-Tpm`; STIG scan.	Secure Boot + HVCI + TPM enforce boot/software integrity; only signed code runs.	HDR-specific.
SR/CR 3.5	Input validation	For host-exposed services/apps, confirm robustness to malformed input; exploit-protection (Exploit Guard / former EMET mitigations: DEP, ASLR, CFG) is enabled to contain malformed-input abuse. **Ext. tools:** Get-ProcessMitigation; protocol fuzzer against exposed services (ISOLATED).	Exploit mitigations on; no crash on malformed input to exposed services.	Do NOT fuzz production.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm errors/crashes are handled without info leakage: error reporting configured, crash dumps protected, no sensitive data in user-visible errors. **Ext. tools:** WER settings review; Event Viewer (application errors).	Graceful error handling; no sensitive info leak.	
SR/CR 3.8	Session integrity	Confirm session integrity — sessions resist replay/hijack; no unauthenticated session path remains. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Session integrity verified individually.	
SR/CR 3.9	Protection of audit information	Protect the Security log: restrict "Manage auditing and security log" (SeSecurityPrivilege) to admins, forward to a write-once SIEM so local tampering cannot erase the trail. **Ext. tools:** secpol (user-rights review); SIEM immutability check.	Audit records protected from unauthorized read/modify/delete.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
HDR 3.10	Support for updates	Patching via Windows Update / **WSUS** / Intune; verify current (`Get-HotFix`, build/patch level) and a rollback path. **Ext. tools:** `Get-HotFix`; WSUS/Intune compliance.	Signed OS/app updates applied promptly; rollback available.	HDR-specific.
HDR 3.11	Physical tamper resistance/detection	Confirm physical/firmware tamper protections: **TPM 2.0** present & owned, BitLocker with TPM+PIN, chassis in a locked area, boot order locked, DMA protection (Kernel DMA Protection) on. **Ext. tools:** Get-Tpm; manage-bde -status; physical inspection.	TPM+BitLocker sealed; DMA protection on; chassis controlled.	HDR-specific.
HDR 3.12	Provisioning product-supplier roots of trust	Confirm the OS trusts only Microsoft-signed boot/kernel components: **Secure Boot** enabled with the Microsoft UEFI CA, Windows code-integrity (WDAC/HVCI) enforcing signed drivers. **Ext. tools:** Confirm-SecureBootUEFI; msinfo32 (Secure Boot State); HVCI status.	Supplier root of trust intact; only signed boot/kernel code runs.	HDR-specific.
HDR 3.13	Provisioning asset-owner roots of trust	Confirm the asset owner controls its own trust anchors: enterprise CA root deployed to Trusted Root store, WDAC policy signed by the asset owner, custom Secure Boot keys where used. **Ext. tools:** certlm.msc (Trusted Root review); signed WDAC policy check.	Asset-owner trust anchors provisioned and managed.	HDR-specific.
HDR 3.14	Integrity of the boot process	Confirm integrity of the boot process — only signed/verified firmware boots (device requirement). **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.4** above (shared steps); confirm this requirement individually and adjudicate it separately.	Integrity of the boot process verified individually.	HDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 4.1	Information confidentiality	**BitLocker** full-disk (TPM+PIN where required): `manage-bde -status`; TLS in transit; EFS/DPAPI for sensitive files. **Ext. tools:** `manage-bde -status`; STIG scan.	Data-at-rest encrypted (BitLocker) and in-transit (TLS).	
SR/CR 4.2	Information persistence	On decommission/reuse, sanitize storage: BitLocker crypto-erase or disk wipe; confirm no recoverable credentials/data; clear cached creds and page/hibernation files (ClearPageFileAtShutdown). **Ext. tools:** manage-bde crypto-erase / cipher /w; verify wipe.	Sensitive data purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Disable TLS 1.0/1.1 and weak ciphers (Schannel registry / GPO); verify `Get-TlsCipherSuite`; FIPS mode where mandated. **Ext. tools:** sslscan (host services); `Get-TlsCipherSuite`; STIG scan.	TLS 1.2/1.3 + strong ciphers; weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 5.1	Network segmentation	**Windows Defender Firewall** ON for all profiles with default-deny inbound + explicit rules: `Get-NetFirewallProfile` / `Get-NetFirewallRule`; block unneeeded inbound; consider IPsec host isolation. **Ext. tools:** Nmap (open inbound ports by segment); `Get-NetFirewallProfile`	Host firewall default-deny inbound; only required flows; profiles enabled.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	On an OT host, disable/remove general-purpose comms (email, IM, arbitrary web) and enforce app allow-listing + egress filtering so the host cannot be used for person-to-person messaging. **Ext. tools:** AppLocker/WDAC review; proxy/egress-filter review.	No general-purpose person-to-person comms on the OT host.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR 5.4	Application partitioning	Separate roles/apps: least-privilege accounts, AppContainer/UAC isolation, separate admin vs operator profiles, or dedicated VMs per function so a compromise is contained. **Ext. tools:** Review account/role separation; VM/session isolation review.	Applications/roles partitioned to contain compromise.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 6.1	Audit log accessibility	Logs accessible in Event Viewer / `wevtutil`; forward via **WEF** + **Sysmon** to the SIEM; **Defender for Endpoint** for EDR telemetry. **Ext. tools:** SIEM/WEF verification; Sysmon config review.	Events accessible and forwarded to SIEM; EDR monitoring active.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: host firewall (Windows Defender Firewall) limits exposure, SYN/connection protections, resource limits; only required services listen. **Ext. tools:** Get-NetFirewallProfile; Nmap (exposed services); load test (ISOLATED).	Attack surface minimized; host resists resource-exhaustion DoS.	
SR/CR 7.2	Resource management	Confirm resource controls: per-process limits / Job Objects / WSRM where used, disk quotas, and monitoring so one process cannot starve the host of CPU/memory/disk. **Ext. tools:** Performance Monitor; quota review.	Resources bounded; no single-process exhaustion.	
SR/CR 7.3	Control system backup	System image/state backup + tested restore; System Restore / recovery media; verify backup job success and integrity. **Ext. tools:** Backup console review; test restore (lab).	Recent verified backup; restore/recovery tested.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Config settings baseline	Apply and verify the STIG/CIS security baseline (GPO/Intune); `gpresult /h report.html`; document deviations. **Ext. tools:** SCC/CIS-CAT compliance scan vs baseline.	Host matches the STIG/CIS baseline; deviations documented.	
SR/CR 7.7	Least functionality	Remove/disable unused features/roles/services (`Get-WindowsOptionalFeature -Online`, `Get-Service`), disable SMBv1, close unused ports, uninstall bloatware. **Ext. tools:** Nmap (open ports); Autoruns; STIG scan.	Only required features/services/ports enabled.	
SR/CR 7.8	Component inventory	Capture OS build, patches, and installed software: `systeminfo`, `Get-HotFix`, `Get-Package`. **Ext. tools:** Inventory/EDR agent; ReadOnlyEnum.	Complete OS/patch/software inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
SCAP: SCC / OpenSCAP / CIS-CAT + STIG Viewer	Baseline compliance (all)	Scan against the **DISA Windows 11 STIG** or **CIS Benchmark**; review findings in STIG Viewer; drives most pass/fail evidence.	Authorized scan account.
PowerShell (Get-*)	Effective state of native controls (most rows)	`Get-MpComputerStatus`, `Confirm-SecureBootUEFI`, `Get-Tpm`, `manage-bde -status`, `Get-NetFirewallProfile`, `auditpol /get /category:*`, `net accounts`.	Read-only queries.
Sysinternals (AccessChk / Autoruns)	Privileges & autostart review (2.1, 7.7)	`accesschk` for rights/ACLs; Autoruns for persistence and unneeded startups.	Read-only.
Nmap	Port/service exposure & segmentation (1.13, 5.x, 7.7)	`nmap -sT -p 445,3389,5985,5986,135-139 -T2` ; scan by segment; confirm SMBv1/legacy closed.	Tune timing on production.
sslscan / testssl.sh	TLS strength of host services (4.3)	`sslscan :3389` / host TLS services; confirm strong ciphers, no TLS1.0/1.1.	Read-only.
Wireshark / tcpdump	SMB/LDAP signing, comm integrity (3.1)	Confirm SMB2 signing and no cleartext auth (SPAN/tap).	Passive; SPAN/tap only.
WEF / Sysmon + SIEM	Audit forwarding & monitoring (2.8, 6.x)	Verify security events and Sysmon telemetry arrive at the SIEM; trigger a test event.	Coordinate with SIEM team.
Nessus / OpenVAS	Known-CVE vulnerability scan (3.2, general)	Authenticated scan for missing patches / CVEs; cross-check MSRC advisories.	ISOLATED/authorized.
ReadOnlyEnum	Host/network enumeration (7.8)	Enumerate services/ports/config read-only.	Read-only.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.